

Defend-The-Core

Annexe 3 : Durcissement des serveurs

Durcissement Ubuntu Server et Windows Server 2022

Défense en profondeur, conformité CIS Benchmark, justification ANSSI

SSH durci · auditd · UFW · sysctl · CIS Benchmark · Nginx · PostgreSQL · Windows Defender · GPO ·
SMBv1 désactivé · RDP NLA

Table des matières

1. Philosophie de durcissement	3
1.1. Défense en profondeur	3
1.2. Moindre privilège	3
1.3. Conformité CIS Benchmark	3
2. Durcissement Ubuntu Server (VLAN 30)	3
2.1. SSH durci	4
2.2. Auditd — surveillance des actions sensibles	4
2.3. UFW — pare-feu local	5
2.4. sysctl — paramètres noyau durcis	5
2.5. Durcissement CIS général	6
2.6. Pile Web durcie	6
3. Durcissement Windows Server 2022 (VLAN 30)	7
3.1. Pare-feu Windows	7
3.2. Politique d'audit	7
3.3. Politique de mots de passe	8
3.4. Gestion des comptes	8
3.5. Windows Defender	8
3.6. Paramètres de registre	9
3.7. Désactivation de SMBv1	9
3.8. RDP — NLA et chiffrement	9
4. GPO de sécurité (Windows)	10
5. Justification ANSSI	10

1. Philosophie de durcissement

Le durcissement d'un serveur consiste à réduire sa surface d'attaque en désactivant tout ce qui n'est pas strictement nécessaire et en renforçant les mécanismes de sécurité qui restent. Pour Defend-The-Core, cette démarche s'inscrit dans trois principes directeurs : la **défense en profondeur**, le **principe du moindre privilège** et la **conformité aux CIS Benchmarks**, eux-mêmes alignés sur les recommandations de l'ANSSI.

1.1. Défense en profondeur

La défense en profondeur repose sur l'empilement de couches de protection **indépendantes**, de sorte que la défaillance ou le contournement d'une seule ne suffise pas à compromettre le système. Chaque couche ajoute une barrière distincte qu'un attaquant doit franchir séparément.

Sur les serveurs du VLAN 30, la chaîne de défense est la suivante : **pare-feu OPNsense** (filtrage inter-VLAN) puis **UFW local** (filtrage de l'hôte), **sysctl** (paramètres noyau : ASLR, anti-spoofing, SYN flood), **auditd** (journalisation des actions sensibles) et enfin **SSH durci** (clés uniquement, root interdit, crypto forte). Aucune de ces couches ne fait confiance à une autre : un flux autorisé par OPNsense reste filtré par UFW, une session SSH acceptée reste surveillée par auditd.

Cette indépendance est essentielle : si une vulnérabilité contournait le pare-feu périphérique, les couches internes (sysctl, auditd, SSH) continueraient de limiter les dégâts et de générer des alertes exploitables par le SIEM Wazuh.

1.2. Moindre privilège

Le principe du moindre privilège s'applique à tous les niveaux : services tournant sous des comptes dédiés sans shell, fichiers en possession stricte (`chmod 600` pour les clés), comptes administratifs isolés derrière le bastion, et ports d'écoute limités au strict métier. Aucun service n'expose plus que ce que sa fonction requiert.

1.3. Conformité CIS Benchmark

Le durcissement suit les **CIS Benchmarks** (Center for Internet Security), référentiels reconnus qui déclinent en contrôles concrets les bonnes pratiques de sécurité. Ces benchmarks servent également de base à l'évaluation continue réalisée par Wazuh (Security Configuration Assessment) : toute dérive de configuration déclenche une alerte. Les recommandations CIS retenues sont celles pertinentes pour un serveur en zone critique, et leur mise en œuvre est justifiée dans les sections suivantes.

Au-delà des CIS, la démarche répond directement aux préconisations de l'**ANSSI** en matière de durcissement des systèmes, de journalisation et d'administration sécurisée (voir section 5).

2. Durcissement Ubuntu Server (VLAN 30)

Le serveur Ubuntu 22.04 LTS du VLAN 30 (10.10.30.10) héberge la pile Web métier (Nginx + PostgreSQL). Son durcissement couvre six domaines : le service SSH, la journalisation auditd, le pare-feu local UFW, les paramètres noyau sysctl, le durcissement CIS général et la pile applicative.

2.1. SSH durci

L'accès SSH est le seul canal d'administration du serveur. Il est verrouillé à l'extrême : **authentification par clé uniquement** (aucun mot de passe), **connexion root interdite** (passage par un compte sudo dédié via le bastion), algorithmes cryptographiques modernes, et limitation stricte des tentatives.

Tableau 1 — Paramètres de durcissement SSH

Paramètre	Valeur	Justification
PermitRootLogin	no	Force l'usage d'un compte sudo dédié, traçable
PasswordAuthentication	no	Authentification par clé uniquement, anti-bruteforce
PubkeyAuthentication	yes	Mécanisme d'authentification retenu
KexAlgorithms	curve25519-sha256, ecdh-sha2-nistp256	Échange de clés modernes, anti attaque par pré-image
Ciphers	chacha20-poly1305, aes256-gcm	Chiffrement symétrique AEAD, confidentialité + intégrité
MACs	hmac-sha2-512-etm, hmac-sha2-256-etm	Codes d'authentification résistants aux collisions
MaxAuthTries	3	Blocage rapide des tentatives de bruteforce
LoginGraceTime	30	Ferme la connexion non authentifiée après 30 s
AllowUsers	ops-admin	Liste blanche stricte d'utilisateurs autorisés
Banner	/etc/issue.net	Avertissement légal avant authentification

Extrait du fichier /etc/ssh/sshd_config.d/50-hardening.conf :

```
# Authentification et accès
PermitRootLogin no
PasswordAuthentication no
PubkeyAuthentication yes
MaxAuthTries 3
LoginGraceTime 30
AllowUsers ops-admin
Banner /etc/issue.net

# Suite cryptographique (algorithme moderne uniquement)
KexAlgorithms curve25519-sha256,ecdh-sha2-nistp256
Ciphers chacha20-poly1305@openssh.com,aes256-gcm@openssh.com
MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com
```

Le compte **ops-admin** n'est accessible qu'en rebond depuis le bastion NixOS (ProxyJump), ce qui ajoute une couche d'authentification forte et d'immuabilité.

2.2. Auditd — surveillance des actions sensibles

Le daemon **auditd** journalise en continu les actions sensibles : modifications de fichiers d'identité et de configuration, exécution de commandes privilégiées, changements de droits. Les journaux sont forwardés vers le SIEM Wazuh pour corrélation. Les règles sont rendues **immuables** via **-e 2** : leur modification exige un

redémarrage, ce qui empêche un attaquant de les désactiver discrètement.

Tableau 2 — Règles auditd clés

Règle	Cible surveillée	Objectif
-w /etc/passwd -p wa	Fichier d'identité	Détecte création/modification de comptes
-w /etc/group -p wa	Fichier de groupes	Détecte élévation de privilèges via groupe
-w /etc/sudoers -p wa	Configuration sudo	Détecte attribution de droits d'administration
-w /etc/ssh/sshd_config -p wa	Configuration SSH	Détecte tentative de backdoor SSH
-w /var/log/auth.log -p wa	Journal d'authentification	Détecte falsification des logs
-a always,exit -F arch=b64 -S execve	Exécution de commandes	Trace toutes les commandes exécutées
-e 2	Verrou d'immuabilité	Règles non modifiables sans redémarrage

2.3. UFW — pare-feu local

UFW (Uncomplicated Firewall) constitue la couche de filtrage de l'hôte, indépendante du pare-feu OPNsense. La politique par défaut est **deny incoming** : seuls les flux explicitement listés sont acceptés. Le SSH n'est autorisé que depuis le bastion ; le HTTP/HTTPS n'est servi que par le reverse proxy.

Tableau 3 — Règles UFW

Règle	Action	Justification
default deny incoming	Deny	Refus par défaut de tout flux entrant
default allow outgoing	Allow	Le serveur initie ses propres flux (MAJ, DNS)
from 10.10.99.20 to any port 22	Allow	SSH uniquement depuis le bastion (VLAN 99)
from 10.10.20.0/24 to any port 80,443	Allow	HTTP/HTTPS depuis le reverse proxy (DMZ) uniquement
from any to any	Deny	Règle finale implicite de blocage

2.4. sysctl — paramètres noyau durcis

Les paramètres noyau sont renforcés via `sysctl` pour activer l'ASLR, empêcher l'attachement à un processus, contrer l'usurpation d'adresse (anti-spoofing) et le SYN flood, et désactiver IPv6 inutilisé.

Tableau 4 — Paramètres sysctl durcis

Paramètre	Valeur	Justification
kernel.randomize_va_space	2	ASLR complet, complique l'exploitation de failles mémoire
kernel.yama.ptrace_scope	1	Restreint ptrace aux processus enfants, anti-injection
net.ipv4.conf.all.rp_filter	1	Anti-spoofing : vérifie la cohérence source/chemin

net.ipv4.conf.all.accept_redirects	0	Ignore les redirections ICMP, anti-MITM
net.ipv4.conf.all.send_redirects	0	Le serveur n'émet pas de redirections ICMP
net.ipv4.tcp_syncookies	1	Protection contre le SYN flood (DoS)
net.ipv4.conf.all.log_martians	1	Journalise les paquets impossible/martien (alerte Wazuh)
net.ipv6.conf.all.disable_ipv6	1	Désactive IPv6 inutilisé, réduit la surface d'attaque

2.5. Durcissement CIS général

Au-delà des domaines précédents, plusieurs contrôles CIS transverses sont appliqués : politique de mots de passe PAM, limites de session, permissions de fichiers, suppression des services inutiles et blacklisting de modules noyau dangereux.

- **PAM** : mots de passe de 14 caractères minimum, 4 classes de caractères (majuscule, minuscule, chiffre, spécial), verrouillage du compte après 5 échecs pendant 30 minutes.
- **Limites de session** : `/etc/security/limits.conf` plafonne les processus par utilisateur (anti fork bomb) et la mémoire, pour empêcher un DoS local d'épuiser les ressources.
- **Permissions fichiers** : fichiers de configuration en `640` ou `600`, journaux en `append-only`, recherche de fichiers SUID inattendus.
- **Services inutiles** : désactivation de `avahi`, `cups`, `modemmanager` et de tout service non requis par le rôle du serveur.
- **Modules noyau blacklistés** : `dccp`, `sctp`, `rds`, `tipc` — protocoles rares non utilisés et historiquement vulnérables.

2.6. Pile Web durcie

Nginx sert de serveur Web frontal. Il masque sa version (`server_tokens off`), injecte des en-têtes de sécurité et limite les protocoles TLS aux versions récentes (1.2 et 1.3) avec des suites cryptographiques fortes.

Tableau 5 — En-têtes et paramètres Nginx

En-tête / paramètre	Valeur	Rôle
server_tokens	off	Masque la version de Nginx, complique le fingerprinting
X-Frame-Options	SAMEORIGIN	Anti clickjacking (encadrement interdit)
X-Content-Type-Options	nosniff	Anti MIME-sniffing
X-XSS-Protection	1; mode=block	Filtre XSS réfléchi côté navigateur
Strict-Transport-Security	max-age=31536000	HSTS : force HTTPS pendant 1 an
ssl_protocols	TLSv1.2 TLSv1.3	TLS modernes uniquement, abandon de TLS 1.0/1.1

PostgreSQL n'écoute que sur `localhost` (`127.0.0.1`) : aucune exposition réseau, connexion uniquement via le socket local depuis Nginx. L'authentification utilise `scram-sha-256` dans `pg_hba.conf`, qui remplace l'obsolète MD5 par un mécanisme à hachage salé résistant aux attaques hors ligne. La base métier

utilise un compte dédié à droits limités, distinct du superutilisateur.

```
# Nginx – durcissement TLS et en-têtes
server_tokens off;
ssl_protocols TLSv1.2 TLSv1.3;
ssl_ciphers ECDHE-ECDSA-AES256-GCM-SHA384:ECDHE-RSA-AES256-GCM-SHA384;
add_header X-Frame-Options SAMEORIGIN always;
add_header X-Content-Type-Options nosniff always;
add_header Strict-Transport-Security "max-age=31536000" always;

# PostgreSQL – pg_hba.conf
host metier metier_app 127.0.0.1/32 scram-sha-256
```

3. Durcissement Windows Server 2022 (VLAN 30)

Le contrôleur de domaine Windows Server 2022 (10.10.30.20) assure l'annuaire Active Directory, le DNS et le DHCP. Son durcissement combine pare-feu hôte, politique d'audit, politique de mots de passe, gestion des comptes, Windows Defender, paramètres de registre et désactivation des protocoles hérités dangereux.

3.1. Pare-feu Windows

Le pare-feu Windows Defender est activé sur les trois profils (domaine, privé, public) en politique **inbound default-deny** : aucune connexion entrante n'est acceptée sauf règle explicite. La journalisation des paquets droppés est activée pour alimenter la détection.

Tableau 6 — Pare-feu Windows Defender

Paramètre	Valeur	Justification
Domain/Private/Public profile	Enabled	Pare-feu actif sur tous les profils
Default Inbound Action	Block	Refus par défaut des connexions entrantes
Default Outbound Action	Allow	Le serveur initie ses propres flux
Log Dropped Packets	Yes	Journalisation des paquets rejetés, corrélation Wazuh
Log Successful Connections	Yes	Traçabilité des connexions acceptées

3.2. Politique d'audit

Toutes les catégories d'audit sont activées pour fournir au SIEM une vision complète de l'activité du serveur. Les événements sont collectés par l'agent Wazuh et corrélés aux signaux provenant des autres hôtes.

Tableau 7 — Politique d'audit Windows

Catégorie	Sous-catégorie	Niveau
Logon/Logoff	Logon, Logoff, Account Lockout	Success + Failure
Account Management	User/Group creation, deletion	Success + Failure

Object Access	File, Registry, Kernel	Success + Failure
Privilege Use	Sensitive privilege use	Success + Failure
Policy Change	Audit policy, auth policy	Success + Failure
Account Logon	Credential validation	Success + Failure

3.3. Politique de mots de passe

La politique de mots de passe, déployée par GPO, impose une longueur et une complexité élevées ainsi qu'un verrouillage automatique du compte en cas d'échecs répétés, conformément aux recommandations CIS et ANSSI.

Tableau 8 — Politique de mots de passe Windows

Paramètre	Valeur	Justification
Minimum length	14	Complexité suffisante pour résister au bruteforce hors ligne
Maximum age	90 jours	Renouvellement périodique, limite la durée de vie d'un secret compromis
Complexity	Enabled	4 classes de caractères obligatoires
Lockout threshold	5 échecs	Verrouillage rapide en cas de bruteforce
Lockout duration	30 minutes	Fenêtre d'attente avant déverrouillage automatique
Reversible encryption	Disabled	Stockage sous forme de hachage, jamais en clair

3.4. Gestion des comptes

Le compte **Administrator** natif est renommé afin de rendre les attaques par énumération de comptes moins efficaces, et le compte **Guest** est désactivé pour éliminer une porte d'entrée sans mot de passe. Aucun compte à privilèges n'est utilisé pour les tâches courantes : l'administration passe par des comptes dédiés et le bastion.

Tableau 9 — Gestion des comptes Windows

Action	Cible	Objectif
Renommage	Administrator	Évite l'énumération du compte par défaut
Désactivation	Guest	Supprime un compte sans mot de passe
Désactivation	Comptes inactifs (90 j)	Réduit la surface d'attaque
Restriction	Administrateurs locaux	Accès uniquement via le bastion

3.5. Windows Defender

L'antivirus natif Windows Defender est activé en mode **real-time** avec protection cloud et protection réseau, et le module anti-ransomware (contrôle d'accès aux dossiers) est activé pour limiter l'impact d'un chiffrement

malveillant.

Tableau 10 — Windows Defender

Fonctionnalité	Valeur	Rôle
Real-time protection	On	Analyse en temps réel des fichiers accédés
Cloud-delivered protection	High	Réputation cloud, détection des menaces émergentes
Network protection	On	Bloque les connexions vers des domaines malveillants
Controlled folder access	On	Anti-ransomware, protège les dossiers sensibles
PUA protection	On	Bloque les applications potentiellement indésirables

3.6. Paramètres de registre

Plusieurs clés de registre renforcent l'authentification et le contrôle de l'environnement : imposition de NTLMv2, désactivation du stockage du hash LM (faible) et de l'AutoRun, et conservation du séquenceur SAS (Ctrl+Alt+Del) pour l'ouverture de session.

Tableau 11 — Paramètres de registre de sécurité

Clé de registre	Valeur	Justification
LmCompatibilityLevel	5	NTLMv2 uniquement, refus des LM/NTLMv1 obsolètes
NoLMHash	1	Ne stocke pas le hash LM (cassable instantanément)
AutoRun	Disabled	Empêche l'exécution automatique depuis un média amovible
DisableCAD	0	Ctrl+Alt+Del obligatoire avant ouverture de session (anti-spoofing de l'écran de login)
ScForceOption	1	Carte à puce requise pour l'ouverture de session interactive (si déployée)

3.7. Désactivation de SMBv1

Le protocole SMBv1 — exploité notamment par l'exploit EternalBlue (WannaCry, NotPetya) — est entièrement désactivé au niveau du serveur et du client. Seules les versions SMB 2 et 3 modernes, prenant en charge le chiffrement, sont autorisées.

```
# Désactivation de SMBv1 (PowerShell, administrateur)
Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol -NoRestart
Set-SmbServerConfiguration -EnableSMB1Protocol $false -Force
Set-SmbClientConfiguration -EnableSecuritySignature $true -Force
```

Argument clé : EternalBlue (MS17-010) a permis en 2017 la propagation mondiale de WannaCry. Désactiver SMBv1 neutralise définitivement ce vecteur, y compris sur des systèmes à jour par mesure de réduction de surface d'attaque.

3.8. RDP — NLA et chiffrement

L'accès RDP, lorsqu'il est requis, exige la **NLA** (Network Level Authentication) : l'authentification a lieu avant l'allocation des ressources de session, ce qui protège le serveur contre les attaques par déni de service et certaines vulnérabilités BlueKeep-like. Le chiffrement est réglé sur **High** (niveau maximal).

Tableau 12 — Paramètres RDP

Paramètre	Valeur	Justification
UserAuthentication (NLA)	Required	Authentification avant allocation de session
SecurityLayer	TLS	Authentification TLS, abandon de la couche RDP héritée
MinEncryptionLevel	High	Chiffrement maximal des données de session
MaxDisconnectionTime	30 min	Déconnexion automatique des sessions inactives

4. GPO de sécurité (Windows)

Quatre objets de stratégie de groupe (GPO) déploient automatiquement les contrôles de sécurité sur le domaine. Ils sont versionnés dans le dépôt Git du projet et appliqués via un cycle DevSecOps, ce qui garantit leur reproductibilité et leur auditabilité.

Tableau 13 — GPO de sécurité Defend-The-Core

GPO	Description	Paramètres clés
DTC-Password-Policy	Politique de mots de passe et de verrouillage	14 car, 90 j, complexité, verrouillage 5/30 min, historique 24
DTC-Workstation-Hardening	Durcissement des postes et serveurs membres	SMBv1 off, NLA, Defender realtime, AutoRun off, LMCompatibilityLevel=5
DTC-Audit-Policy	Journalisation complète des événements de sécurité	Toutes catégories Success+Failure, forward vers Wazuh
DTC-Software-Restriction	Restriction logicielle et contrôle d'exécution	AppLocker (listes blanches), chemins d'exécution contrôlés

5. Justification ANSSI

Le tableau ci-dessous établit la correspondance entre les grandes recommandations de l'ANSSI et leur mise en œuvre concrète dans le cadre du durcissement des serveurs. Il démontre que chaque préconisation se traduit par un contrôle technique vérifiable.

Tableau 14 — Correspondance recommandations ANSSI

Recommandation ANSSI	Mise en œuvre dans le durcissement
Cloisonnement en zones de confiance	Serveurs en VLAN 30 (critique), filtrés par OPNsense default-deny et UFW local

Principe du moindre privilège	Services sous comptes dédiés, fichiers en 600, AllowUsers SSH, ports métier uniquement
Authentification forte	SSH par clé uniquement, root interdit, NTLMv2 imposé, NLA RDP
Journalisation et traçabilité	auditd immuable (-e 2) sur Linux, audit complet Windows, forward vers Wazuh
Durcissement des systèmes	CIS Benchmark (sysctl, PAM, registre, Defender), SMBv1 désactivé, TLS 1.2/1.3
Mise à jour continue	Unattended-upgrades sécurité (Ubuntu), WSUS/Defender (Windows), évaluation SCA Wazuh

Cette annexe complète le document maître d'architecture. Les annexes voisines traitent du réseau et d'OPNsense (annexe 1), du SIEM Wazuh (annexe 2) et de l'administration sécurisée via le bastion NixOS (annexe 4).